Phần 1: Phân tích lỗ hổng

1. Xác định nguồn gốc trực tiếp gây rò rỉ dữ liệu

- **Dòng log gây thảm họa:** Dòng đầu tiên lúc **08:15 T2** (`campuspay_beta_users.xlsx` | Thành viên A | **Editor** | **Anyone with the link**).
- **Cơ chế kỹ thuật & Tổ hợp quyền:** Thành viên A đã vi phạm nghiêm trọng **"Quy tắc Cờ Đỏ Bảo mật"** khi kết hợp đồng thời hai yếu tố:
    - **Phạm vi mở công khai (`Anyone with the link`):** Biến file dữ liệu khách hàng thành một đường dẫn trôi nổi trên internet mà bất kỳ ai cũng có thể truy cập không cần xác thực.
    - **Quyền hạn cao nhất (`Editor`):** Cho phép bất kỳ người lạ nào nhấp vào link không chỉ xem mà còn chỉnh sửa, xóa, hoặc tải toàn bộ dữ liệu (họ tên, SĐT, số dư), dẫn đến việc file bị phát tán và phá hủy trên nhóm Facebook công khai.

2. Ba giả thuyết "Email người lạ" truy cập file `campuspay_api_keys.txt`

Dù file được thiết lập `Restricted – Email B` vào lúc 09:30 T2, sự xuất hiện của email lạ lúc 10:00 T3 bắt nguồn từ một trong ba nguyên nhân sau:

1. **Thay đổi cấu hình chia sẻ sau đó (Misconfiguration Update):** Sau 09:30 T2, một thành viên có quyền quản trị (hoặc chính Trưởng nhóm) đã vô tình đổi lại quyền của file từ `Restricted` sang `Anyone with the link` hoặc chủ động cấp quyền trực tiếp cho email của người lạ.
2. **Lộ thông tin định danh tài khoản (Credential Compromise):** Tài khoản email hoặc phiên đăng nhập của Email B bị lộ/phishing, tạo điều kiện cho kẻ xấu sử dụng danh tính hợp lệ của B để truy cập vào file nằm trong danh sách `Restricted`.
3. **Kế thừa quyền từ thư mục cha (Folder Permission Inheritance):** Tệp `campuspay_api_keys.txt` được di chuyển hoặc đặt bên trong một thư mục gốc có bật chế độ chia sẻ rộng (`Anyone with the link` dạng Editor/Viewer), khiến cơ chế phân quyền kế thừa ghi đè lên giới hạn ban đầu của tệp.

Phần 2: Sửa lỗi & Nghiệm thu

3. Bảng cấu hình quyền chia sẻ đúng chuẩn

Tên file	Quyền đúng	Phạm vi đúng	Giải thích ngắn gọn

`campuspay_beta_users.xlsx`	**Viewer** (hoặc Không chia sẻ)	**Restricted** (Chỉ email Quản lý / Phụ trách hệ thống)	Dữ liệu nhạy cảm của khách hàng tuyệt đối không được mở rộng cho toàn bộ đội ngũ hoặc bên ngoài.
`campuspay_api_keys.txt`	**Viewer** (chỉ đọc)	**Restricted** (Chỉ email Kỹ thuật cốt cán)	Thông tin khóa API bảo mật, chỉ giới hạn cho lập trình viên trực tiếp xử lý cấu hình hệ thống.
`slide_pitch_v8.pptx`	**Viewer** / **Commenter**	**Restricted** (Nội bộ nhóm & Nhà đầu tư có thời hạn)	Cho phép đối tác xem bài thuyết trình gọi vốn nhưng bảo vệ tài liệu gốc khỏi việc chỉnh sửa hay phát tán bừa bãi.

4. Vô hiệu hóa link cũ và ứng dụng "Set Expiration Date"

- **Thao tác vô hiệu hóa link cũ nhanh nhất:** Chuyển đổi trạng thái chia sẻ tổng quát của tệp từ **"Anyone with the link"** về lại chế độ **"Restricted"**. Ngay lập tức, mọi URL công khai cũ đang trôi nổi trên internet sẽ trở nên vô hiệu hóa và trả về màn hình báo lỗi truy cập từ chối.
- **Khi nào nên dùng tính năng "Set Expiration Date"?:**
    - Cần sử dụng tính năng này khi chia sẻ tài liệu mật (như Slide Pitch, Business Plan) với **các bên thứ ba bên ngoài tổ chức** (Nhà đầu tư tiềm năng, Ban cố vấn, Đối tác chiến lược, Kiểm toán viên).
    - **Lý do thay vì thu hồi thủ công:** Giúp tự động hóa việc chấm dứt quyền truy cập sau một khoảng thời gian cam kết (ví dụ sau 14 ngày gọi vốn), loại bỏ hoàn toàn rủi ro quên thu hồi thủ công khiến tài liệu tiếp tục bị lưu trữ trái phép sau khi kết thúc công việc.